Contoso Ltd. · Company policy

Information Security and Generative AI Guidelines

Document no. **SEC-003** Owner **Information Security Team** Revised **2026-04-01** Classification **Internal**

1. Information Classification

Classification	Examples	Handling rule
Public	Press releases, product catalogs	No restrictions
Internal	Company policies, general business documents	Use only on the corporate network and in approved services
Confidential	Unreleased business plans, costs, customer contract terms	Share only with those who need to know; prior approval required
Top secret	M&A, core source code, performance review results	In principle, may not be entered into AI services

2. Principles for Using Generative AI

- For work, use only 'Contoso AI' (built on Microsoft Azure), the company-approved service.
- Entering work materials into publicly available external generative AI services is prohibited (including through personal accounts).
- Public and Internal materials may be entered into the portal. Confidential materials may be used only with prior approval from the Information Security Team and only within the knowledge sources designated in the portal.
- Top secret materials may not be entered.

> Customer personal information must not be entered: this includes resident registration numbers (RRNs), phone numbers, addresses, and any other identifiable data. Unreleased financial information, performance reviews, and core source code are also prohibited. If it is absolutely necessary, mask or de-identify names and contact details before use.

3. Verifying Outputs

- A person must always verify AI answers. When sources are provided, check the original text.
- Do not rely on an AI answer as the sole basis for a final decision on legal, financial, or HR matters.

4. Incident Response

If personal or confidential information has been leaked, or a leak is suspected, report it to the Information Security Team (ext. 7777) within 1 hour and submit an incident report within 24 hours.

5. Accounts and Access Control

- All business systems require Microsoft Entra ID sign-in (SSO) and multi-factor authentication (MFA).
- Passwords must be at least 12 characters long and changed every 90 days.
- AI portal query logs are retained for 1 year, with personal information masked before storage.

6. Transfer Outside the Company

Sending documents classified Confidential or above outside the company requires DLP approval. USB storage devices may not be used.